

API Security Vulnerability Assessment

Consolidated Technical Report

1. Vulnerability Details: API Security

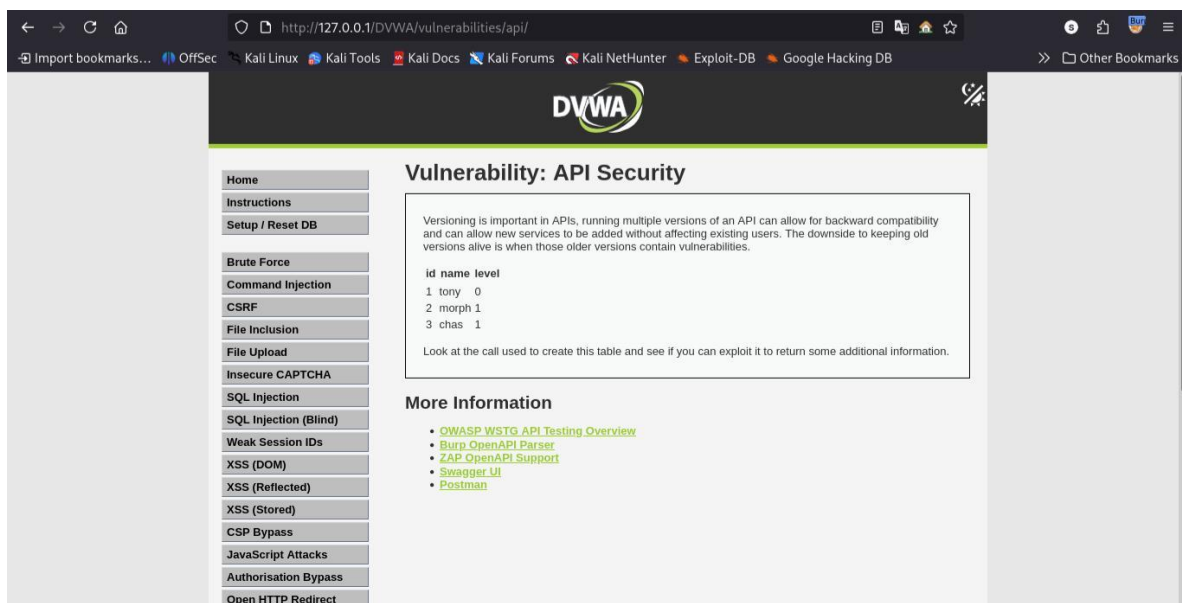
Vulnerability Name	Unsecure Old API Version (Data Leak)
Severity	High
Affected Endpoint	http://127.0.0.1/DVWA/vulnerabilities/api/v1/user/
Security Level	Low

Description

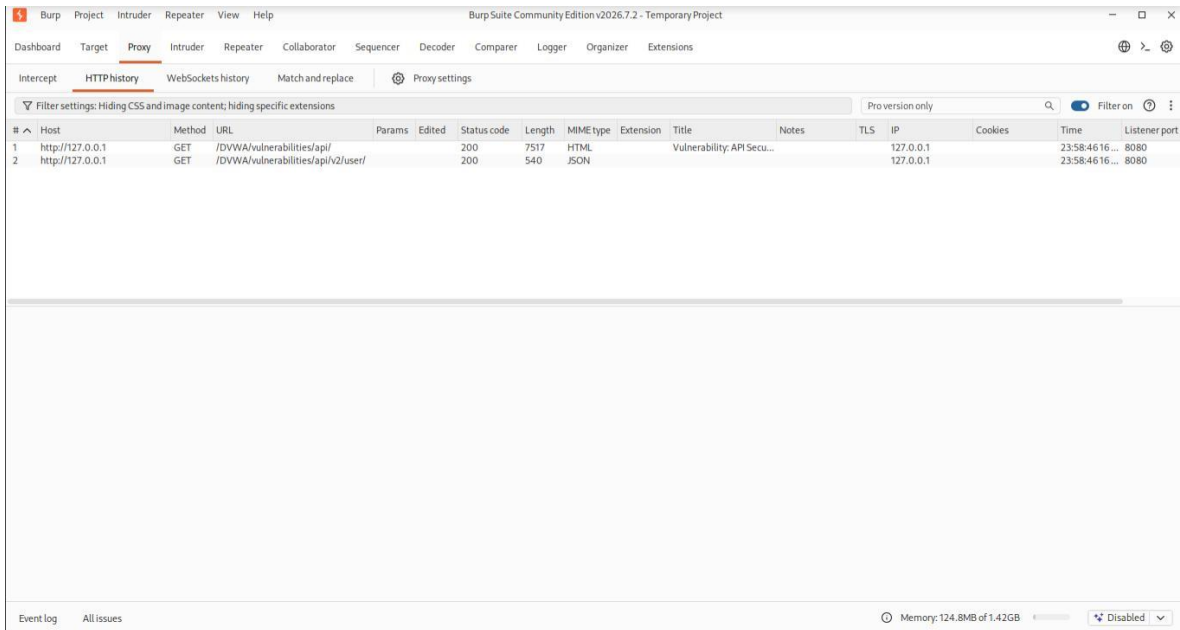
The website uses an old API version (/v1/user/). This old version is still active on the server. When we visit this link, the site shows sensitive user data like hidden password hashes.

Steps to Reproduce

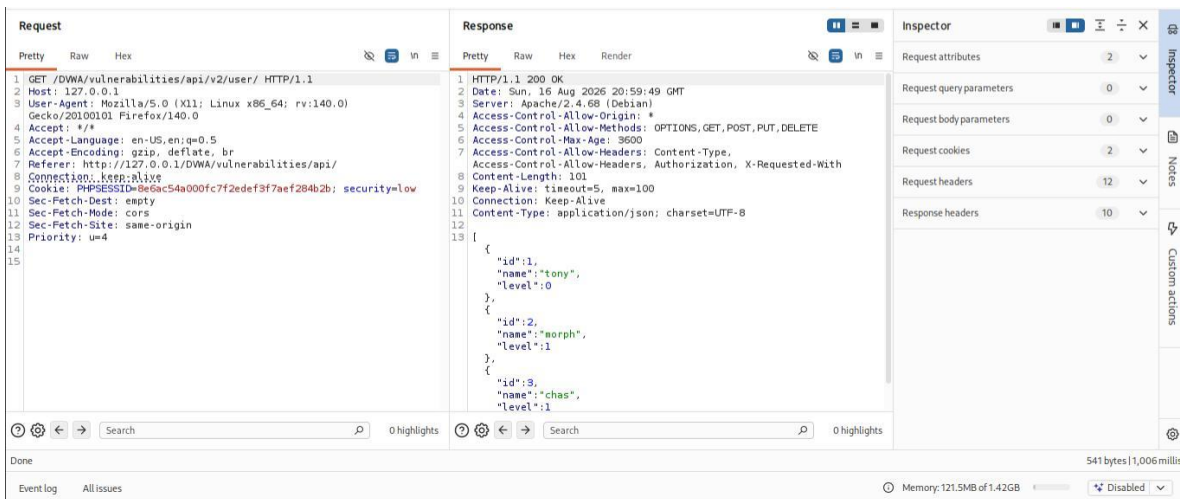
Open the API Security page in DVWA.



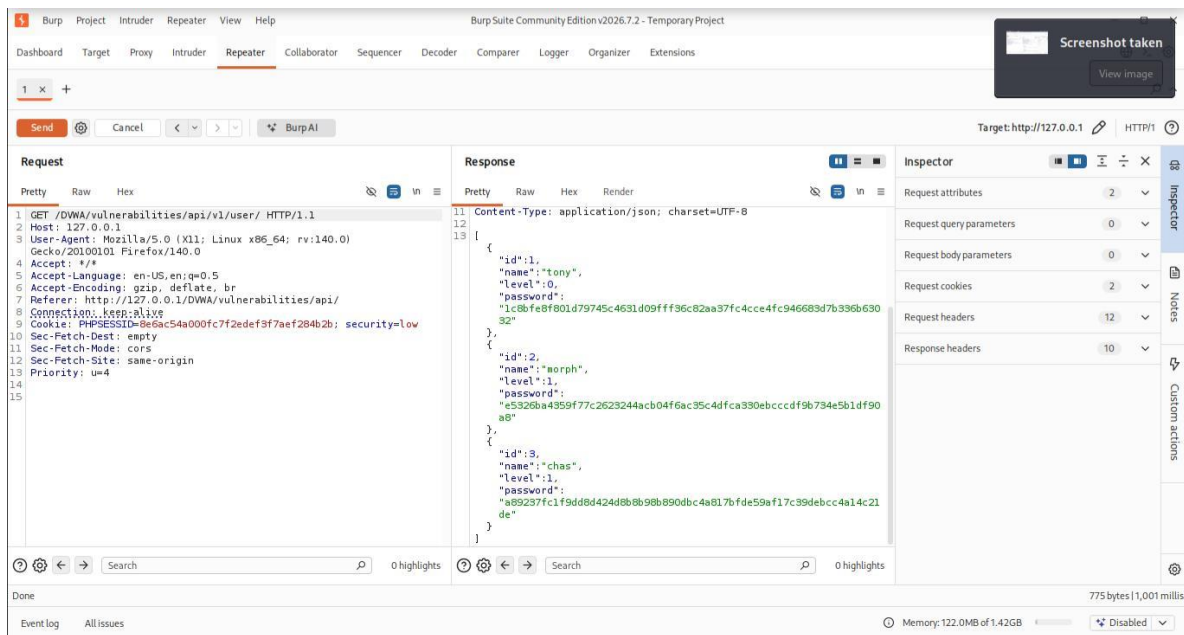
Capture the web request in Burp Suite Proxy. You can see the app uses /v2/user/.



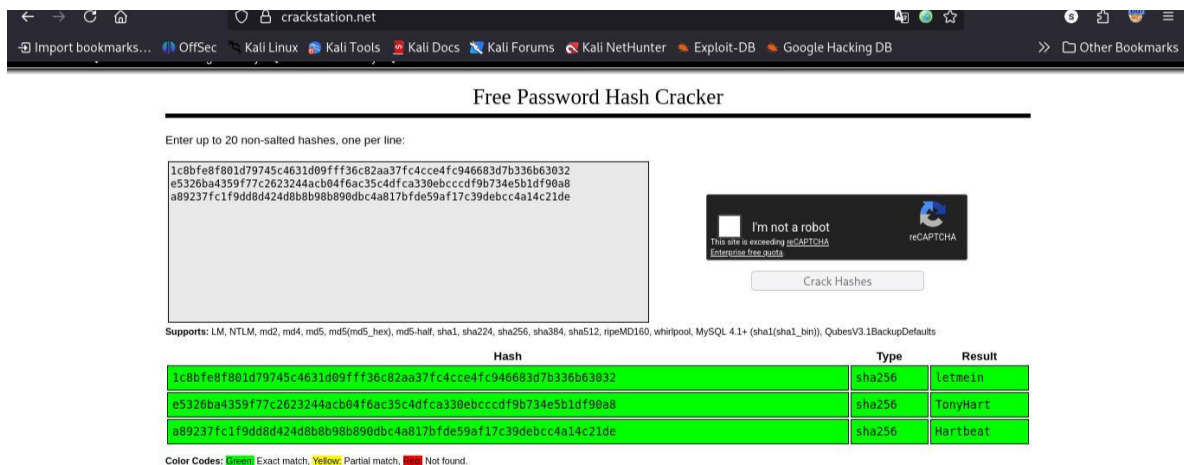
Send the request to Repeater and send it. You can see version 2 does not show password



Change /v2/user/ to /v1/user/ and click Send. The response shows JSON data with user password hashes.



Copy the hashes to CrackStation to get the real passwords (letmein, TonyHart, Hartbeat).



[Download CrackStation's Wordlist](#)

How CrackStation Works

CrackStation uses massive pre-computed lookup tables to crack password hashes. These tables store a mapping between the hash of a password, and the correct password for that hash. The hash values are indexed so that it is possible to quickly search the database for a given hash. If the hash is present in the database, the

Impact

An attacker can easily read the old API and get user passwords. This allows the attacker to log in to other users' accounts.

Remediation / Recommendation

Delete Old APIs: Remove old API versions like /v1/ when you build a new version.

Hide Passwords: Do not send password hashes or private data in API responses.

Add Protection: Protect all API links with strong login checks.

2. Privilege Escalation (Mass Assignment)

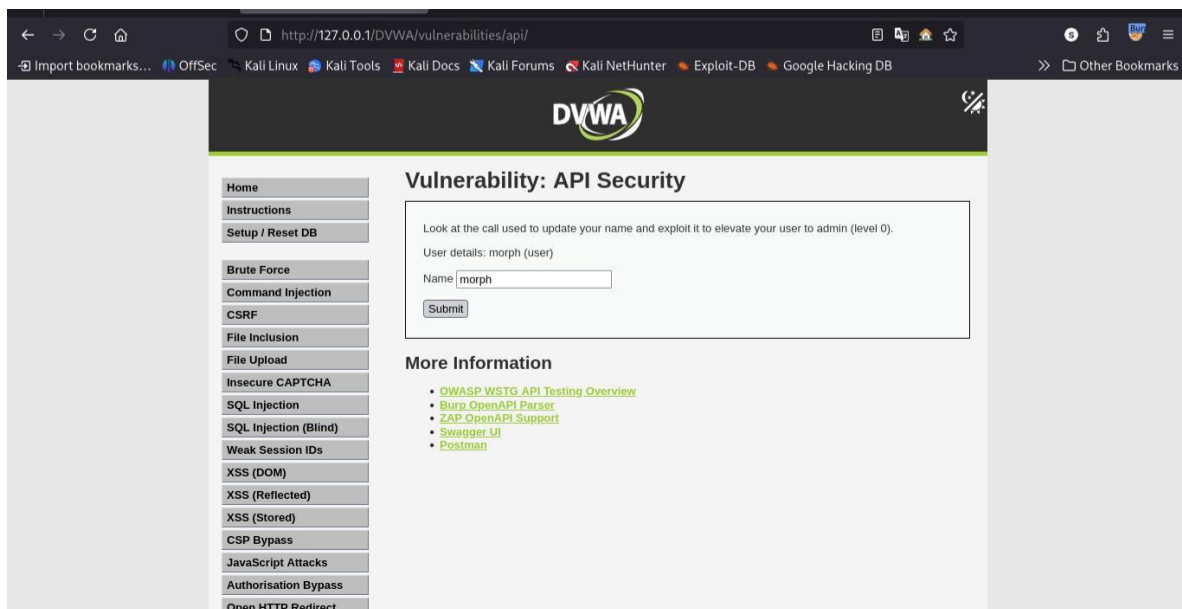
Vulnerability Name	Privilege Escalation via API Mass Assignment
Severity	High
Affected Endpoint	http://127.0.0.1/DVWA/vulnerabilities/api/v2/user/2
Security Level	Medium

Description

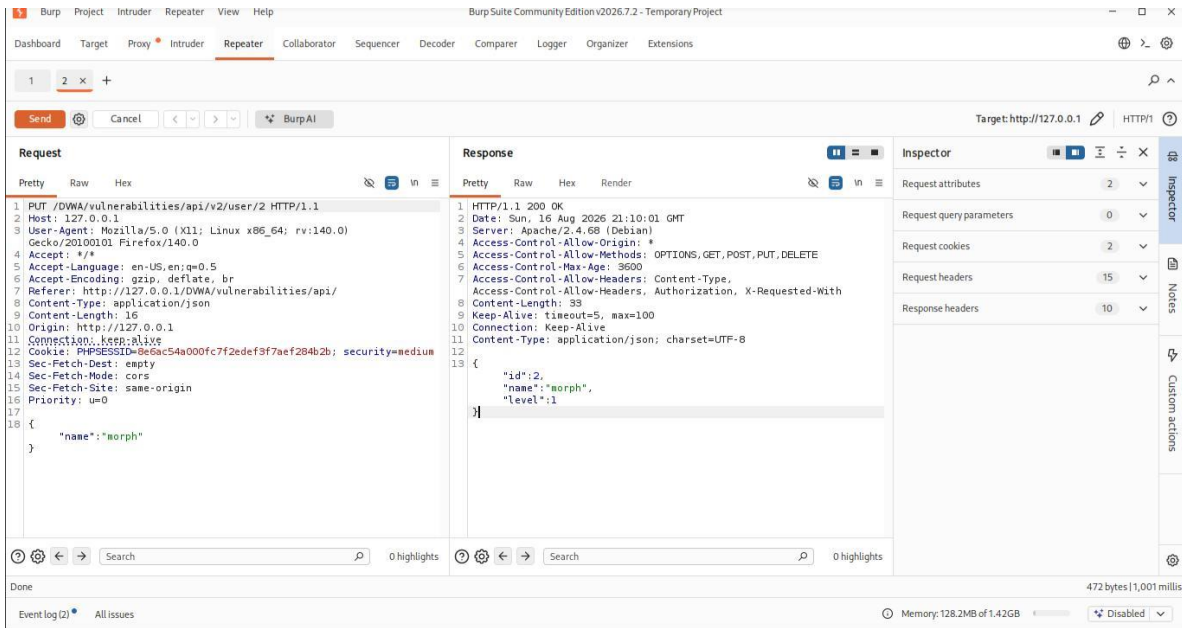
The application allows normal users to update their profile data using a PUT request. However, the server does not filter input parameters properly. A user can send an extra JSON parameter ("level": 0) in the request body to change their account privilege level to admin (level 0).

Steps to Reproduce

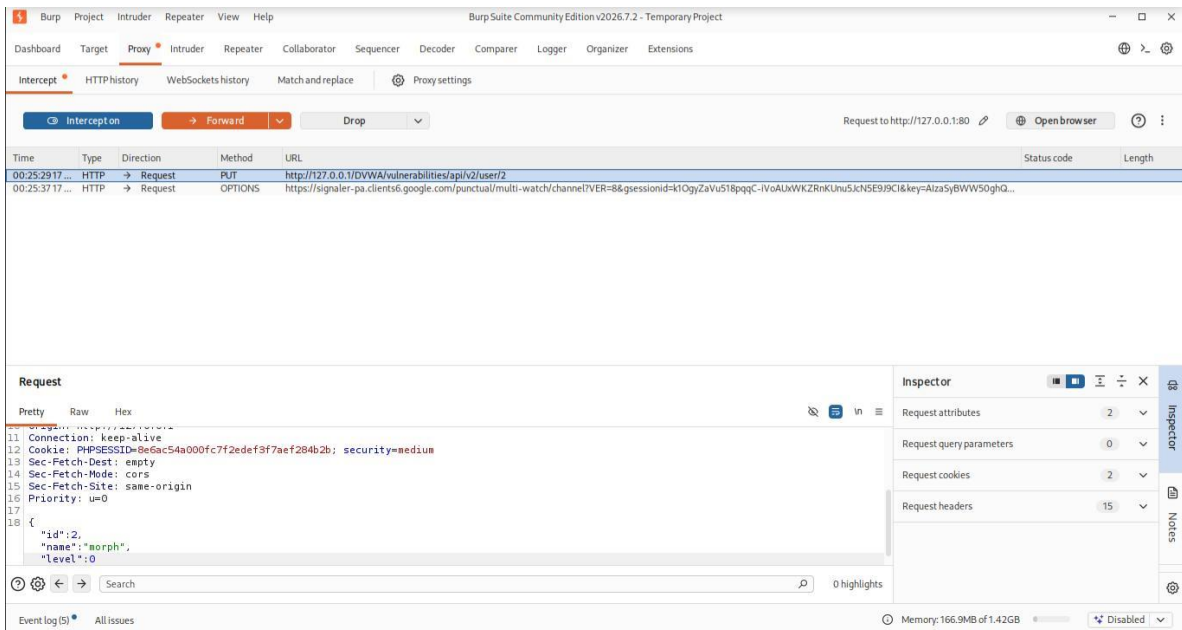
Open the API Security page in DVWA while logged in as a normal user (morph).



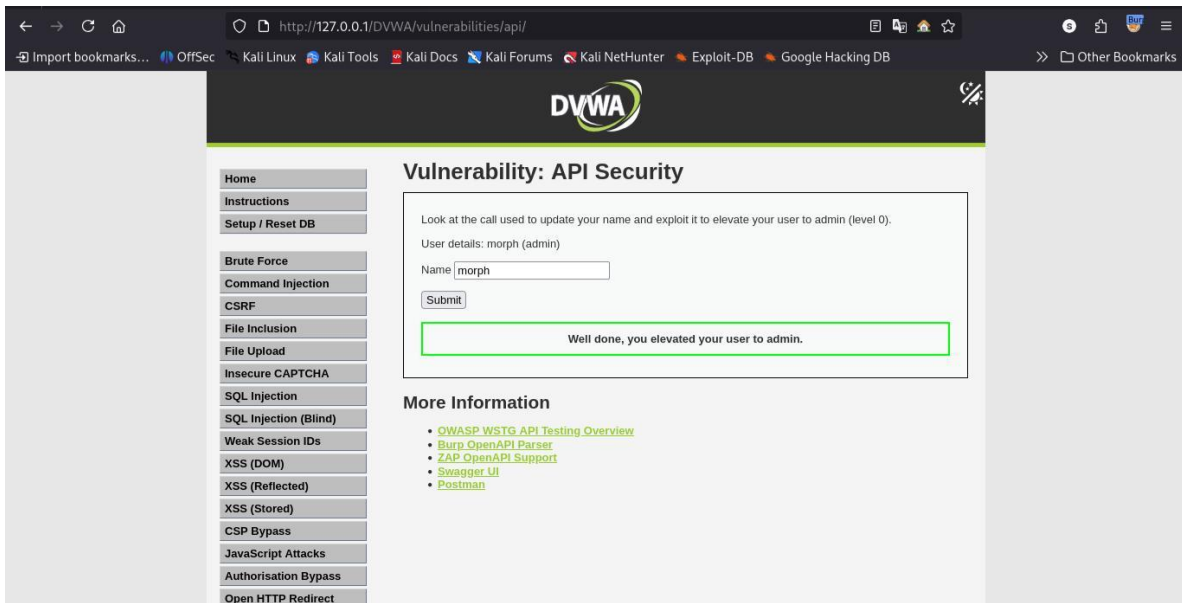
Submit the form to change the username and capture the request in Burp Suite Repeater. Notice the standard request only updates "name": "morph".



In Burp Suite Proxy or Repeater, modify the request body by adding “level”: 0 alongside “id”: 2 and “name”: “morph”.



Forward or send the modified request. The server accepts the new parameter and updates the user level.



Impact

An attacker can change their user level from regular user to administrator. This leads to full control over the application and access to administrative features.

Remediation / Recommendation

Use Allow-lists: Only accept expected user fields (like name) in update requests.

Block Admin Fields: Do not allow clients to send administrative parameters like level or role.

Server Verification: Check user rights on the server side before changing any privilege settings